



Universidad Nacional Autónoma de México

Posgrado en Ciencia e Ingeniería de la Computación

Docente: Dr. Wolf Iszaevich Gunnar Eyal

Alumno: Kurt Axel Ruiz Ayala

Materia: Temas selectos de redes y seguridad en cómputo

Trabajo: Análisis de seguridad de una arquitectura de red corporativa híbrida (on-premise + nube)

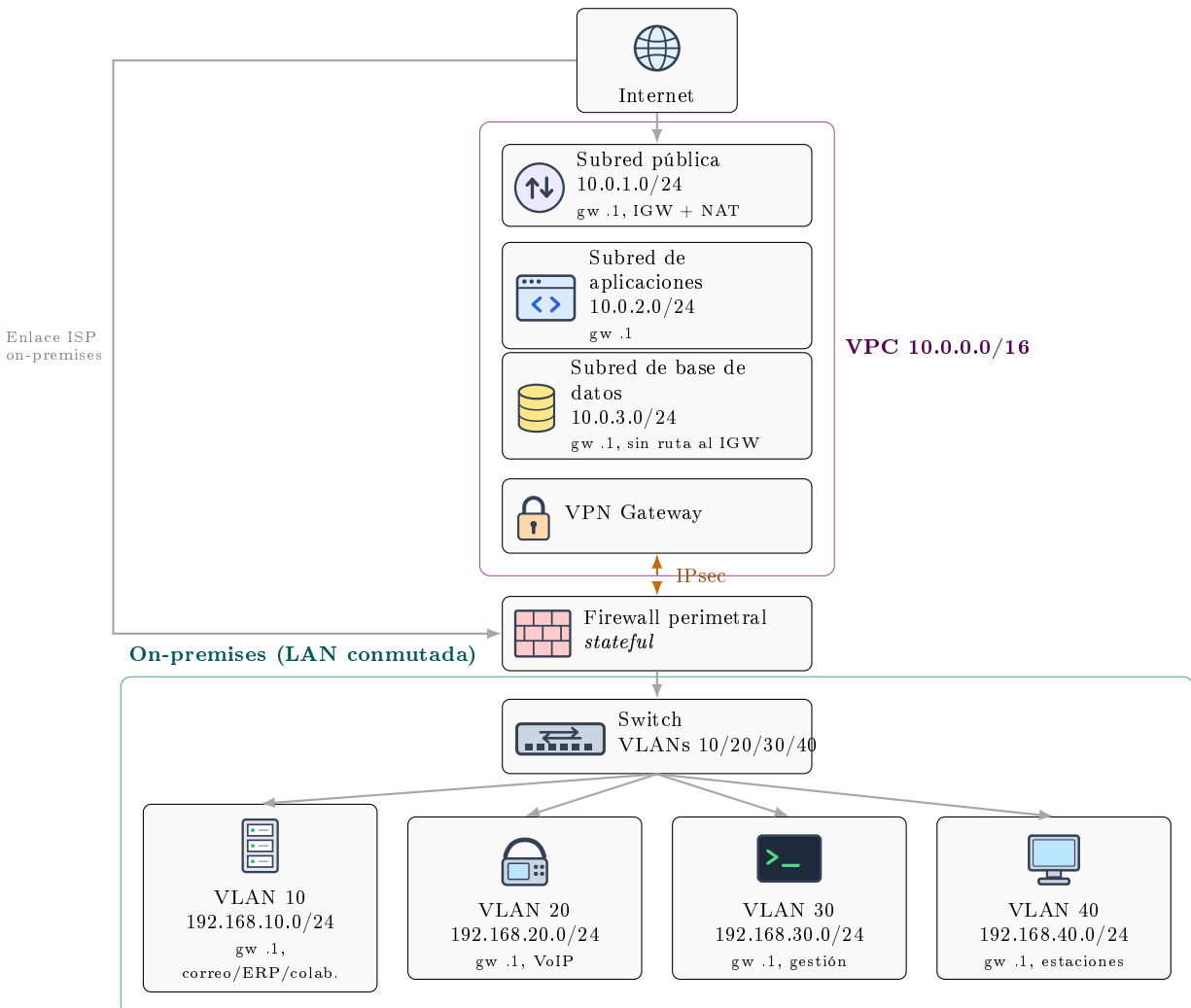
Semestre 2027-1

Ciudad de México, 17 septiembre de 2026

Análisis de seguridad de una arquitectura híbrida on-premises / nube

Se analiza una organización en oficina con red on-premises segmentada en VLANs, servidores en una nube privada virtual (VPC) y una VPN sitio a sitio como interconexión. El análisis por capa se concentra en las tres capas donde aplican las clases de ataque estudiadas, manipulación de capa de enlace y reconocimiento activo: enlace, red y transporte.

1 Diagrama de red



2 Análisis de ataques por capa

Escala de probabilidad. *Alta:* requiere solo acceso al segmento local o acceso remoto no autenticado con herramientas públicas. *Media:* requiere un pivote previo o credenciales válidas. *Baja:* requiere posición privilegiada o una cadena de varios pasos. El reconocimiento no vulnera confidencialidad de forma directa; su impacto propio es bajo y su riesgo es habilitante, como precondition de la explotación posterior.

2.1 Capa de enlace

a) VLAN hopping por suplantación de switch (DTP) y doble etiquetado 802.1Q. Descripción: Un host en un puerto de acceso fuerza la negociación de troncal vía DTP y queda como miembro de todas las VLANs permitidas, o bien inyecta una trama con dos etiquetas 802.1Q: el primer switch retira solo la etiqueta de la VLAN nativa y reenvía la trama restante hacia una VLAN a la que el atacante no tiene acceso [1]. **Superficie:** Puertos de acceso de la VLAN 40 (estaciones) con DTP habilitado por defecto y VLAN nativa compartida con tráfico de datos. **CIA:** C e I altas si alcanza la VLAN 10 (correo/ERP/colaboración) o la VLAN 30 (gestión); D baja. **Probabilidad:** Alta si el switch conserva la configuración de fábrica (DTP activo, VLAN nativa = VLAN de datos); baja si ya hay hardening de puertos.

b) ARP spoofing dentro del dominio de difusión. Descripción: ARP no autentica sus respuestas [2]; el atacante envía respuestas ARP falsificadas que asocian su MAC con la IP del gateway u otro host, quedando en la ruta del tráfico (on-path) para interceptarlo, modificarlo o descartarlo. **Superficie:** Cualquier VLAN alcanzada por el atacante, en particular la VLAN 40 por su mayor exposición y variedad de endpoints. **CIA:** C alta (intercepción de tráfico interno en claro), I alta (modificación en tránsito), D media (uso como sumidero de tráfico). **Probabilidad:** Alta dentro del mismo segmento sin Dynamic ARP Inspection; herramientas públicas (arp spoof, ettercap) lo hacen trivial.

2.2 Capa de red

a) Descubrimiento por barrido ICMP. Descripción: Sondas ICMP echo, timestamp o máscara identifican hosts vivos antes del barrido de puertos [8]. **Superficie:** Subred pública 10.0.1.0/24 desde Internet; segmento interno tras pivote. **CIA:** C baja (habilitante), I nula, D nula. **Probabilidad:** Alta hacia la subred pública, media hacia el interior; filtrar ICMP no elimina el descubrimiento porque nmap recurre a sondas TCP.

b) Evasión por fragmentación IP. Descripción: La sonda se parte en fragmentos IP pequeños para que un firewall o IDS sin reensamblado no reconozca el patrón; es fragmentación de capa de red, no de TCP [8, 5]. **Superficie:** Firewall perimetral e IDS que evalúen sin reensamblar. **CIA:** Habilitante. **Probabilidad:** Media; depende de si el firewall reensambla, cosa habitual en equipos stateful modernos.

c) Ocultamiento de origen por señuelos. Descripción: El barrido intercala direcciones de origen falsas junto con la real, de modo que el defensor no puede aislar al atacante [8]. **Superficie:** Registros del firewall e IDS. **CIA:** No ataca CIA del objetivo; degrada la atribución. **Probabilidad:** Media; su límite es el filtrado de ingreso, que impide salir a los orígenes falsificados.

2.3 Capa de transporte

a) Barridos TCP evasivos (SYN, ACK, NULL, FIN, Xmas, Maimon, Window). Descripción: Explotan la máquina de estados de TCP [4] enviando combinaciones de banderas para inferir el estado de cada puerto; los sigilosos no llevan SYN y evaden el registro que solo contabiliza intentos de

conexión. **Superficie:** Firewall (UDP 500/4500 del túnel visibles), subred pública, interior tras pivote. **CIA:** Habilitante. **Probabilidad:** Alta en la subred pública, media en el interior.

b) **Barrido UDP. Descripción:** Un puerto UDP cerrado responde ICMP tipo 3 código 3 y uno abierto suele callar, de modo que abierto y filtrado son indistinguibles y el barrido tarda horas por la limitación de tasa ICMP [9]. **Superficie:** Servicios UDP sensibles: IKE en 500/4500, DNS en 53, SIP/RTP de la VLAN 20 si sale a Internet. **CIA:** Habilitante, con foco en los servicios de control. **Probabilidad:** Media; lento y ruidoso, pero apunta a los servicios de mayor valor.

3 Mitigaciones

Ataque	Capa	Mitigación (parámetros)	Efecto	Responsable
VLAN hopping	Enlace	Deshabilitar DTP (<code>switchport nonegotiation</code>); modo access/trunk explícito; VLAN nativa dedicada sin tráfico de datos [1]	Elimina la negociación automática y el doble etiquetado	Adm. switch / Redes
ARP spoofing	Enlace	Dynamic ARP Inspection atada a DHCP snooping; port security (límite de MACs por puerto) [3]	Descarta respuestas ARP no correlacionadas con el snooping	Adm. switch / Redes
Barrido ICMP	Red	Filtrar ICMP echo entrante; sin cómputo en 10.0.1.0/24	Parcial: evade con sondas TCP	Adm. firewall / Redes
Fragmentación IP	Red	Reensamblado y normalización previos a la inspección (defrag por objetivo)	Elimina la evasión	Adm. firewall / SOC
Señuelos	Red	Filtrado de ingreso BCP 38; correlación de flujos	Parcial: no elimina la ambigüedad	Redes / SOC
Barridos TCP evasivos	Transporte	Firewall stateful con descarte silencioso (<code>drop</code> , no <code>reject</code>); IDS de barrido [6, 7]	Reduce el rápido; el lento persiste	Adm. firewall / SOC
Barrido UDP	Transporte	Descarte silencioso en UDP; limitar tasa de ICMP <i>unreachable</i> saliente	Parcial: ralentiza y desinforma	Adm. firewall

4 Riesgos residuales y pregunta abierta

4.1 Riesgos residuales por ámbito

- **On-premises: reconocimiento este-oeste.** Endurecer la capa de enlace (DTP deshabilitado, DAI, port security) cierra el salto directo entre VLANs, pero no sustituye el filtrado en capa 3: si el enrutamiento entre VLANs no aplica ACLs, una estación comprometida en 192.168.40.0/24 sigue alcanzando y barriendo 192.168.10.0/24 por la ruta legítima entre subredes. *Acción:* ACLs inter-VLAN restrictivas o firewall este-oeste entre segmentos; hosts señuelo internos que alerten al primer paquete recibido.
- **Nube: exposición permanente de la subred pública.** El escaneo continuo contra 10.0.1.0/24 no se elimina, se absorbe. *Acción:* cero cómputo en la subred pública (solo gateways gestionados); balanceador al frente; restringir UDP 500/4500 por IP de origen del VPN Gateway.

- **Interconexión: barrido lento bajo umbral.** Ninguna mitigación perimetral por umbral detecta con fiabilidad un barrido espaciado por debajo de la ventana de conteo [6]. *Acción:* detección basada en flujo [7] e IDS interno, con correlación temporal sobre ventanas largas y no solo por umbral fijo.

4.2 Pregunta abierta: VPN sitio a sitio contra enlace dedicado

Superficie de ataque: El enlace dedicado elimina el endpoint IKE público: desaparecen UDP 500 y 4500 expuestos y el barrido que hoy revela la existencia de la VPN, junto con la exposición del tráfico a la ruta pública. A cambio añade una superficie nueva: un enlace “dedicado” es lógicamente dedicado pero físicamente compartido en la red del operador, lo que introduce aprovisionamiento incorrecto (cross-connect mal etiquetado hacia otro cliente), personal del operador con acceso al plano de datos y un punto único de falla si no hay redundancia.

Mitigaciones en capa de enlace y red: Cifrado por salto con MACsec sobre el cross-connect para no depender de la confianza en el operador; si el enrutamiento pasa de estático a dinámico, autenticar las sesiones y aplicar filtros de prefijo estrictos en ambos sentidos; y, de forma pragmática, conservar IPsec por encima del enlace dedicado como defensa en profundidad, con costo marginal casi nulo.

Costo/beneficio: El enlace dedicado se justifica por disponibilidad, latencia determinista y jitter acotado, relevantes para la VLAN 20 de VoIP, no por seguridad. En seguridad pura la ganancia neta sobre un IKEv2 bien configurado es modesta: se cambia un riesgo criptográfico que la organización controla por un riesgo de confianza en un tercero que no controla, a un costo uno o dos órdenes de magnitud mayor. Para el tamaño del caso no se paga por seguridad; si se contrata, que sea por VoIP y disponibilidad, conservando IPsec.

Referencias

- [1] S. A. Rouiller, *Virtual LAN Security: Weaknesses and Countermeasures*, SANS Institute InfoSec Reading Room, 2003.
- [2] D. C. Plummer, *An Ethernet Address Resolution Protocol*, RFC 826, IETF, 1982.
- [3] D. Bruschi, A. Ornaghi y E. Rosti, “S-ARP: a Secure Address Resolution Protocol,” *19th Annual Computer Security Applications Conference (ACSAC)*, IEEE, 2003.
- [4] W. Eddy, *Transmission Control Protocol (TCP)*, RFC 9293, IETF, 2022.
- [5] M. de Vivo, E. Carrasco, G. Isern y G. O. de Vivo, “A review of port scanning techniques,” *ACM SIGCOMM Computer Communication Review*, vol. 29, no. 2, pp. 41-48, 1999.
- [6] M. Almseidin, M. Al-Kasassbeh y S. Kovacs, “Detecting Slow Port Scan Using Fuzzy Rule Interpolation,” *2nd Int. Conf. on New Trends in Computing Sciences (ICTCS)*, IEEE, 2019.
- [7] M. Sangeen, N. A. Bhatti y K. Kifayat, “PortScout: A Communication Flow-Based Approach to Detect Port Scanning Evasion Attacks,” IEEE, 2025.
- [8] G. F. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*, Nmap Project, 2009.
- [9] Nmap Project, *UDP Scan (-sU)*, Nmap Reference Guide. <https://nmap.org/book/scan-methods-udp-scan.html>